Vulnerability Assessment Report

Target Website: https://testphp.vulnweb.com

Intern: Saylee Degloorkar

Domain: Cyber Security

Tools Used: Nmap, OWASP ZAP (Passive Scan), Browser Developer Tools

1. Introduction:

This report presents the outcome of a vulnerability assessment conducted on an intentionally vulnerable web application developed by OWASP for cybersecurity training purposes. The assessment focuses on identifying common security weaknesses present in the application using standard security assessment tools.

The objective of this assessment is to detect potential vulnerabilities, analyze their impact, and classify the associated risks. This activity also helps in understanding the practical aspects of web application security testing.

2. Objectives:

- To identify open ports and publicly exposed services.
- To detect security vulnerabilities in the web application.
- To categorize vulnerabilities based on risk levels (High / Medium / Low).
- To provide suitable remediation recommendations.
- To assess the overall security posture of the web application.

3. Scope:

The scope of this vulnerability assessment is limited to the publicly available training website:

https://testphp.vulnweb.com

This website is intentionally vulnerable and is safe to use for educational and cybersecurity training purposes. No unauthorized systems, private networks, or production environments were included in this assessment.

4. Tools Used:

- **Nmap: -** Port scanning and service detection.
- **OWASP ZAP (Zed Attack Proxy):-** Web application vulnerability scanning.
- **Browser Developer Tools: -** Inspect cookies, HTTP headers, and security configurations.

5. Methodology: The vulnerability assessment was conducted using the following steps:

Step 1: The target website was identified and verified as safe for testing.

Step 2: Nmap was used to scan the website and identify open ports and service.

Step 3: OWASP ZAP was used to perform passive scanning and identify vulnerabilities.

Step 4: Browser Developer Tools were used to analyze cookies and security headers.

Step 5: Identified vulnerabilities were analyzed and classified based on risk level.

Step 6: Recommendations were provided to mitigate the identified vulnerabilities.

6. Findings:

Finding 1: Open HTTP Port (Port 80)

Tool Used: Nmap

Risk Level: Medium

Description: The Web application allows communication over HTTP, which is an unencrypted protocol.

Impact: attackers may intercept sensitive information using man in the middle attacks.

Recommendation: 1. Enforce HTTPS communication, 2. Redirect HTTP traffic to HTTPS, 3. Use SSL/TLS certificates.

```
(c) Microsoft Corporation. All rights reserved.

C:\Users\vaish>nmap -sV testphp.vulnweb.com
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-24 14:04 +0530
Nmap scan report for testphp.vulnweb.com (44.228.249.3)
Host is up (0.047s latency).
Other addresses for testphp.vulnweb.com (not scanned): 64:ff9b::2ce4:f903
rDNS record for 44.228.249.3: ec2-44-228-249-3.us-west-2.compute.amazonaws.com
Not shown: 999 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
80/tcp open  http    nginx 1.19.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.33 seconds
```

Finding 2: Missing Security Headers

Tool Used: Nmap: Used for scanning open ports and identifying running services on the target system.

OWASP ZAP (Zed Attack Proxy): Utilized to perform passive web application vulnerability scanning and detect potential security issues.

Browser Developer Tools: Used to examine cookies, HTTP request/response headers, and security-related configurations.

Finding 3: Cross-Site Scripting (XSS)

Tool Used**:** OWASP ZAP

Risk Level**:** High

Description: The application does not properly validate user input, which allows attackers to inject malicious scripts.

Impact: Steal session cookies, Hijack user sessions, Execute malicious scripts.

Recommendation: Validate user input, encode output properly, Use secure frameworks.

Finding 4: Information Disclosure

Tool Used: Browser Developer Tools

Risk Level: low

Description: The application exposes technology information in HTTP headers.

Impact: Attackers can use this information to identify vulnerabilities.

Recommendation: Hide server information.

Finding 5: Cookie Security Issues

Tool Used**:** Browser Developer Tools.

Risk Level**:** Medium

Description: Cookies do not use Secure or Http Only flags.

Impact: Attackers may steal cookies and hijack sessions.

Recommendation: Enable: Secure Flag, Http Only.

Finding 6: Sensitive Information Exposure

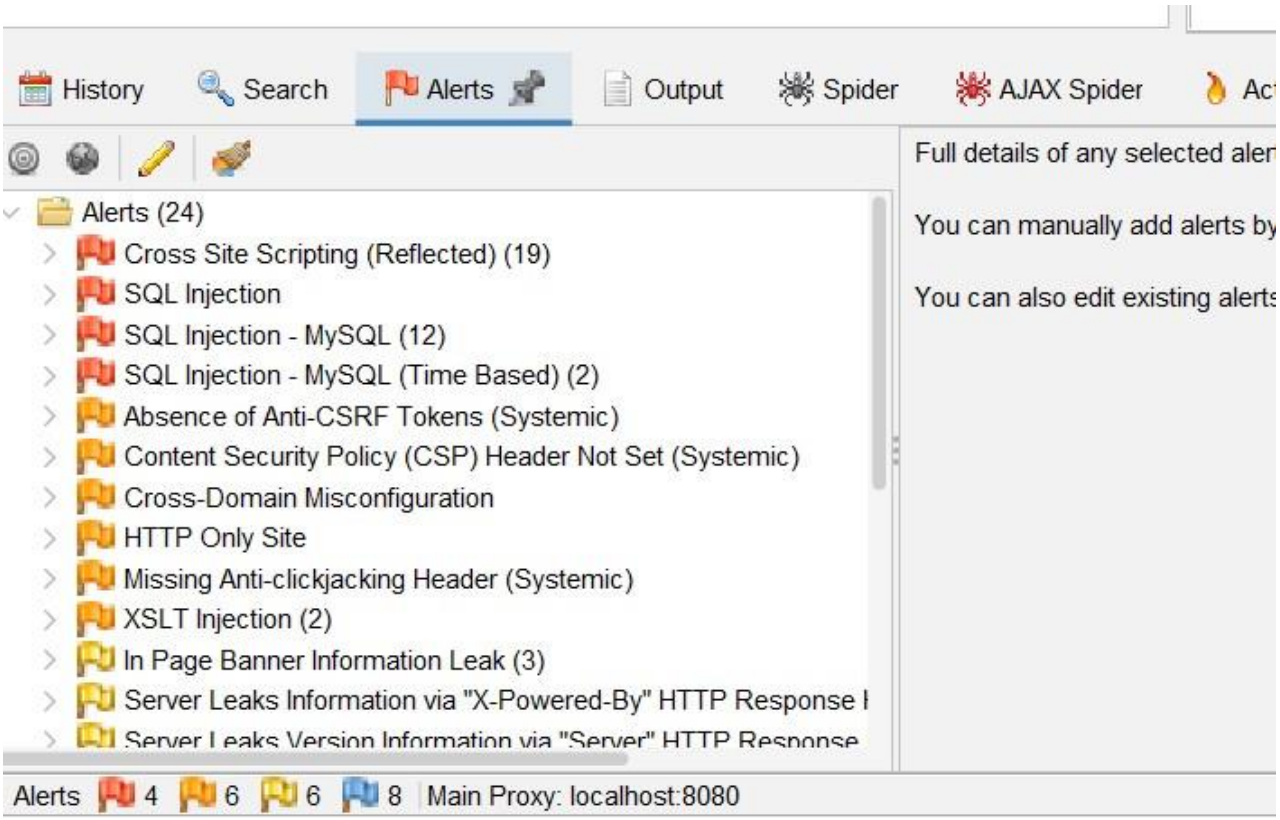
Tool Used: OWASP ZAP

Risk Level: Low

Description: Some sensitive application information is exposed.

Impact: Attackers may use this information for further attacks.

Recommendation: Limit sensitive information exposure.



7. Risk Summary

High Risk: 4

Medium Risk: 6

Low Risk: 6

Informational: 8

8. Conclusion:

The vulnerability assessment identified several security vulnerabilities in the OWASP Juice

Shop web application. The most critical vulnerability identified was Cross-Site Scripting (XSS), which may allow attackers to steal user data and hijack sessions. Other vulnerabilities include missing security headers, cookie security issues, and information disclosure.